AA

# PUBLIC PORTFOLIO EDITION

**PERMANENTLY SANITIZED**

Sensitive public target identifiers, infrastructure details,
organization-specific names, account names, certificate identifiers,
and reusable exploit material have been permanently redacted.
Private RFC1918 addresses are retained where they support the methodology.
The original report and evidence remain private.

Prepared for professional portfolio publication




الجمهورية اليمنية
وزارة التربية والتعليم والبحث العلمي
جامعة العلوم والتكنولوجيا
كلية الحوسبة وتقنية المعلومات

# تقرير اختبار اختراق تطبيق ويب

## تقييم ثغرة تنفيذ أوامر عن بعد في Atlassian Confluence

### CVE-2022-26134 - تقرير فني للتسليم

| | |
|---|---|
| جهة التدريب / العميل | PixelMind |
| نوع التقرير | تقرير اختبار اختراق تطبيق ويب |
| الهدف | [redacted]:443 |
| الحالة | ثغرة مؤكدة - حرجة |
| العام الأكاديمي | 2026 |

أُعد هذا التقرير للتسليم الأكاديمي/المؤسسي.



| | |
|---|---|
| إعداد | عمار يحيى محمد عيقان |
| المشرف | شهاب الحيي |

## بيانات الوثيقة

| | |
|---|---|
| اسم التقرير | تقرير اختبار اختراق تطبيق ويب - Confluence RCE |
| مستوى السرية | سري - للاستخدام الداخلي/الأكاديمي فقط |
| رقم الإصدار | 1.0 |
| تاريخ الإصدار | 02-05-2026 |
| مصدر الأدلة | لقطات شاشة ومخرجات أوامر مقدمة من منفذ الاختبار |

## قيود استخدام التقرير

- هذا التقرير لا يمنح أي صلاحية لاختبار أنظمة خارج نطاق التفويض المكتوب.
- تمت صياغة الأدلة بحيث تدعم المعالجة والتحقق دون نشر تفاصيل استغلال قابلة لإعادة الاستخدام.
- أي مؤشرات اختراق أو عناوين خارجية مذكورة في التقرير يجب التعامل معها كمؤشرات للفحص والاحتواء لا كتعليمات تشغيلية.
- توصيات المعالجة قابلة للتكييف بحسب بيئة العميل وسياسات التغيير الداخلية.

## فهرس المحتويات


| القسم | الصفحة |
|---|---|
| 1. الملخص التنفيذي | ٤ |
| 2. نطاق العمل والقيود | ٥ |
| 3. منهجية الاختبار | ٦ |
| 4. ملخص بيئة الهدف | ٧ |
| 5. ملخص النتائج وتصنيف المخاطر | ٨ |
| 6. تفاصيل الثغرة الحرجة F1 | ٩ |
| 7. الأدلة الداعمة | ١٠ |
| 8. مؤشرات الاختراق والملاحظات التشغيلية | ١٣ |
| 9. تحليل الأثر | ١٤ |
| 10. خطة المعالجة والتوصيات | ١٥ |
| 11. قائمة إعادة الاختبار | ١٦ |
| 12. الخاتمة والمراجع | ١٧ |

## 1. الملخص التنفيذي

تم تنفيذ تقييم أمني محدود على هدف يعمل عبر بروتوكول HTTPS ويستضيف تطبيق Atlassian Confluence. أظهرت نتائج الفحص وجود ثغرة حرجة من نوع تنفيذ أوامر عن بعد مرتبطة بالمعرف CVE-2022-26134. تم التحقق من قابلية الاستغلال بطريقة مقيدة وآمنة من خلال أوامر نظامية غير مدمرة، وكانت النتيجة المؤكدة أن التنفيذ تم بصلاحية root داخل بيئة التطبيق/الحاوية.

| البند | النتيجة |
|---|---|
| مستوى الخطورة | حرج / Critical |
| حالة الثغرة | مؤكدة |
| نوع الأثر | تنفيذ أوامر عن بعد دون مصادقة |
| صلاحية التنفيذ الملحوظة | root داخل الحاوية |
| الإصدار المرصود | Confluence 7.9.3 |
| أولوية المعالجة | فورية - احتواء وتحديث ثم إعادة اختبار |

### الخلاصة الإدارية

- تمثل الثغرة خطراً مباشراً على سرية وسلامة وتوافر النظام؛ لأنها تسمح بتنفيذ أوامر على الخادم المتأثر.
- ظهور نتيجة whoami بقيمة root يرفع شدة الأثر، حتى لو كان التنفيذ داخل حاوية، لأن التطبيق وبياناته ومجلداته المركبة تصبح معرضة للخطر.
- وجود خدمة/منفذ غير معتاد مرتبط بـ nc ومهمة cron خارجية يشير إلى ضرورة تنفيذ فحص احتواء جنائي شامل وعدم الاكتفاء بالتحديث فقط.
- يُنصح بإيقاف التعرض العام مؤقتاً، أخذ نسخة جنائية من السجلات والملفات المهمة، تحديث Confluence إلى إصدار آمن مدعوم، ثم إعادة اختبار الاستغلال والتحقق من إزالة المؤشرات المشبوهة.

## 2. نطاق العمل والقيود

| | |
|---|---|
| عنوان الهدف | [redacted] |
| المنفذ | TCP/443 |
| البروتوكول | HTTPS |
| نوع الاختبار | تحقق من ثغرة مع جمع أدلة نظامية محدودة |
| الأدلة المتاحة | لقطة فحص، مخرجات أوامر نظامية، وملاحظات شبكة/عمليات |
| القيود | لم يتم إجراء اختبار شامل لكل وظائف التطبيق أو فحص قاعدة البيانات بشكل كامل |

## 3. منهجية الاختبار

اعتمد العمل على المزج بين فحص آلي أولي وتحقيق يدوي محدود بهدف إثبات وجود الثغرة وتقييم أثرها دون تنفيذ إجراءات تخريبية أو نشر تفاصيل استغلال قابلة لإعادة الاستخدام.

| المرحلة | الوصف | المخرجات |
|---|---|---|
| الاستطلاع | تحديد الخدمة والمنفذ والتطبيق المتأثر | Confluence على HTTPS |
| الفحص الآلي | استخدام قالب/فحص مرتبط بـ CVE-2022-26134 | نتيجة Critical وبيانات الهدف |
| التحقق اليدوي المحدود | تنفيذ أوامر قراءة غير مدمرة للتحقق من السياق | whoami = root ومعلومات النظام |
| جمع الأدلة | استخراج معلومات بيئة التشغيل والشبكة والعمليات | إصدار التطبيق، نظام التشغيل، المنافذ، cron |
| التقييم | تحليل الأثر وتحديد الأولويات | خطة احتواء ومعالجة وإعادة اختبار |

## 4. ملخص بيئة الهدف

| | |
|---|---|
| اسم المضيف | d03b9e5e5d53 |
| نظام التشغيل | Alpine Linux v3.9.4 |
| النواة | Linux 6.8.0-106-generic x86_64 |
| مجلد العمل | var/atlassian/confluence/ |
| مسار التثبيت | opt/atlassian/confluence/ |
| مجلد البيانات | var/atlassian/confluence/ |
| إصدار Confluence | 7.9.3 |
| إصدار Java | OpenJDK/8u212 |
| زمن التشغيل | days, 13:35 28 |
| بيئة التشغيل | حاوية Docker - وجود /.dockerenv |

### ملاحظات الشبكة والتخزين

| العنصر | القيمة المرصودة | الدلالة |
|---|---|---|
| واجهة الشبكة | eth0 - 172.18.0.2/16 | عنوان داخلي داخل شبكة Docker |
| البوابة | 172.18.0.1 | بوابة الشبكة الداخلية |
| خدمات Confluence | java/8090 و java/8091 | خدمات التطبيق/Synchrony |
| خدمة محلية | java/127.0.0.1:8000 | خدمة داخلية غير معرضة مباشرة |
| منفذ غير معتاد | nc/5555 | مؤشر خطر يتطلب احتواء وفحصاً فورياً |
| قرص البيانات | var/atlassian/confluence - / 99.9G / 71% | مجلد بيانات التطبيق مركب على قرص مستقل |

## 5. ملخص النتائج وتصنيف المخاطر

يوضح الجدول التالي النتائج الرئيسة التي ظهرت أثناء التحقق. تم ترتيب النتائج بحسب الأولوية العملية للمعالجة وليس بحسب عدد الأدلة فقط.

| المعرف | العنوان | الخطورة | الحالة | الأولوية |
|---|---|---|---|---|
| F1 | تنفيذ أوامر عن بعد في Confluence - CVE-2022-26134 | حرجة | مؤكدة | فورية |
| F2 | مؤشرات استمرارية/نشاط غير اعتيادي | حرجة | مرصودة | فورية |
| F3 | تشغيل الخدمة بصلاحية root داخل الحاوية | عالية | مرصودة | عالية |
| F4 | مكونات وإصدارات قديمة في بيئة التطبيق | متوسطة | مرصودة | مجدولة |

### معيار التصنيف المستخدم




| التصنيف | الوصف المختصر |
|---|---|
| حرجة | ثغرة يمكن أن تؤدي إلى تنفيذ أوامر أو سيطرة واسعة أو تسريب بيانات حساس دون شروط معقدة. |
| عالية | مشكلة تؤثر بوضوح على سرية أو سلامة أو توافر النظام وتتطلب معالجة قريبة. |
| متوسطة | مشكلة تزيد مساحة الهجوم أو تضعف الضبط الأمني لكنها لا تثبت وحدها اختراقاً كاملاً. |

## 6. تفاصيل الثغرة الحرجة F1

تتعلق النتيجة بثغرة CVE-2022-26134 في Atlassian Confluence Server/Data Center. حسب استشارة Atlassian الرسمية، ترتبط الثغرة بحقن OGNL وتسمح بتنفيذ أوامر دون مصادقة على الإصدارات المتأثرة. تم رصد الإصدار 7.9.3 في بيئة الهدف، وهو إصدار قديم ويتطلب التحديث إلى إصدار آمن ومدعوم.

| المعرف | F1 |
|---|---|
| اسم الثغرة | Confluence RCE - CVE-2022-26134 |
| التصنيف | Remote Code Execution / OGNL Injection |
| درجة الخطورة | Critical - CVSS 9.8 |
| المكون المتأثر | Atlassian Confluence Server / Data Center |
| الإصدار المرصود | CONF_VERSION=7.9.3 |
| المصادقة المطلوبة | لا توجد / Unauthenticated |
| ناقل الهجوم | Network |
| الأثر | تنفيذ أوامر، قراءة/تعديل ملفات، فتح اتصالات خارجية، تعطيل الخدمة |

### حالة التحقق

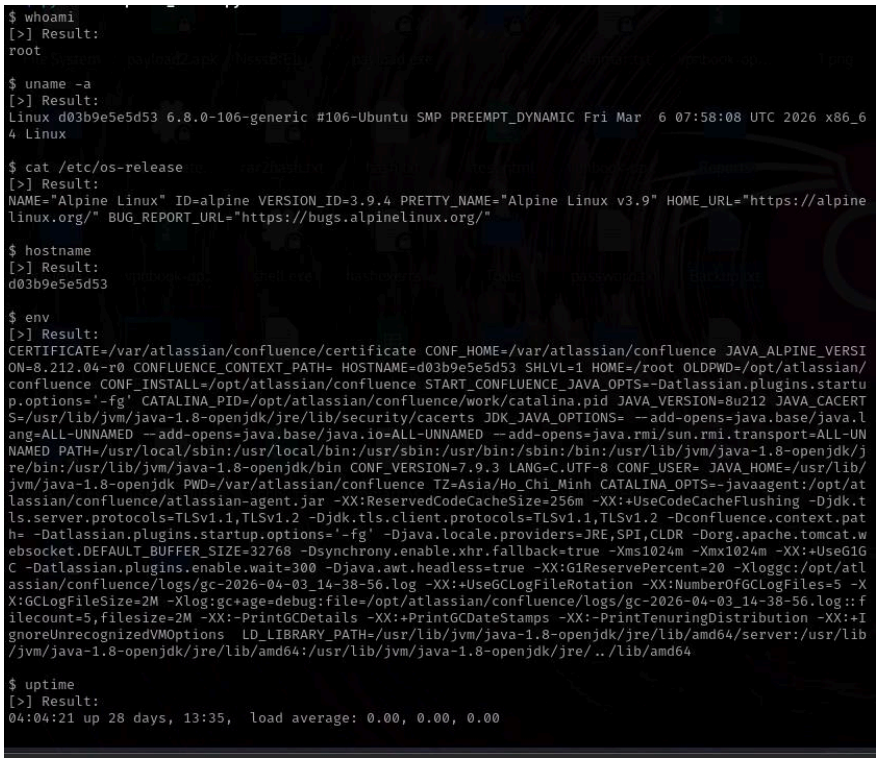
- تم تأكيد تنفيذ الأمر whoami وكانت النتيجة root.
- أظهرت المتغيرات البيئية أن الخدمة تعمل ضمن مسارات /opt/atlassian/confluence و/var/atlassian/confluence.
- تم التعامل مع التحقق بوصفه إثبات أثر فقط، ولم يتم تضمين مسار الاستغلال أو الحمولة التنفيذية في التقرير.

## 7. الأدلة الداعمة

تعرض هذه الصفحة الأدلة البصرية والنتائج المختصرة التي تثبت وجود الثغرة وأثرها.

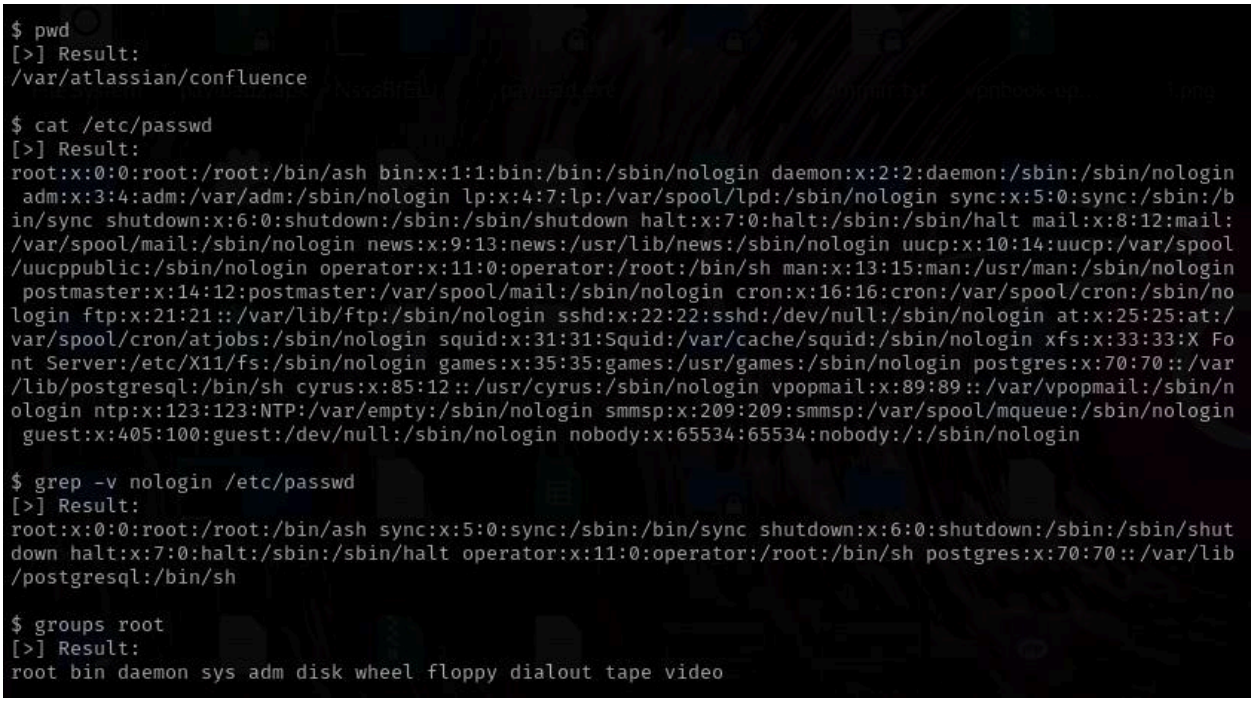



الشكل 1. نتيجة الفحص التي توضح الهدف، نوع الثغرة، مستوى الخطورة، ونتيجة التنفيذ بعد حجب تفاصيل الاستغلال.

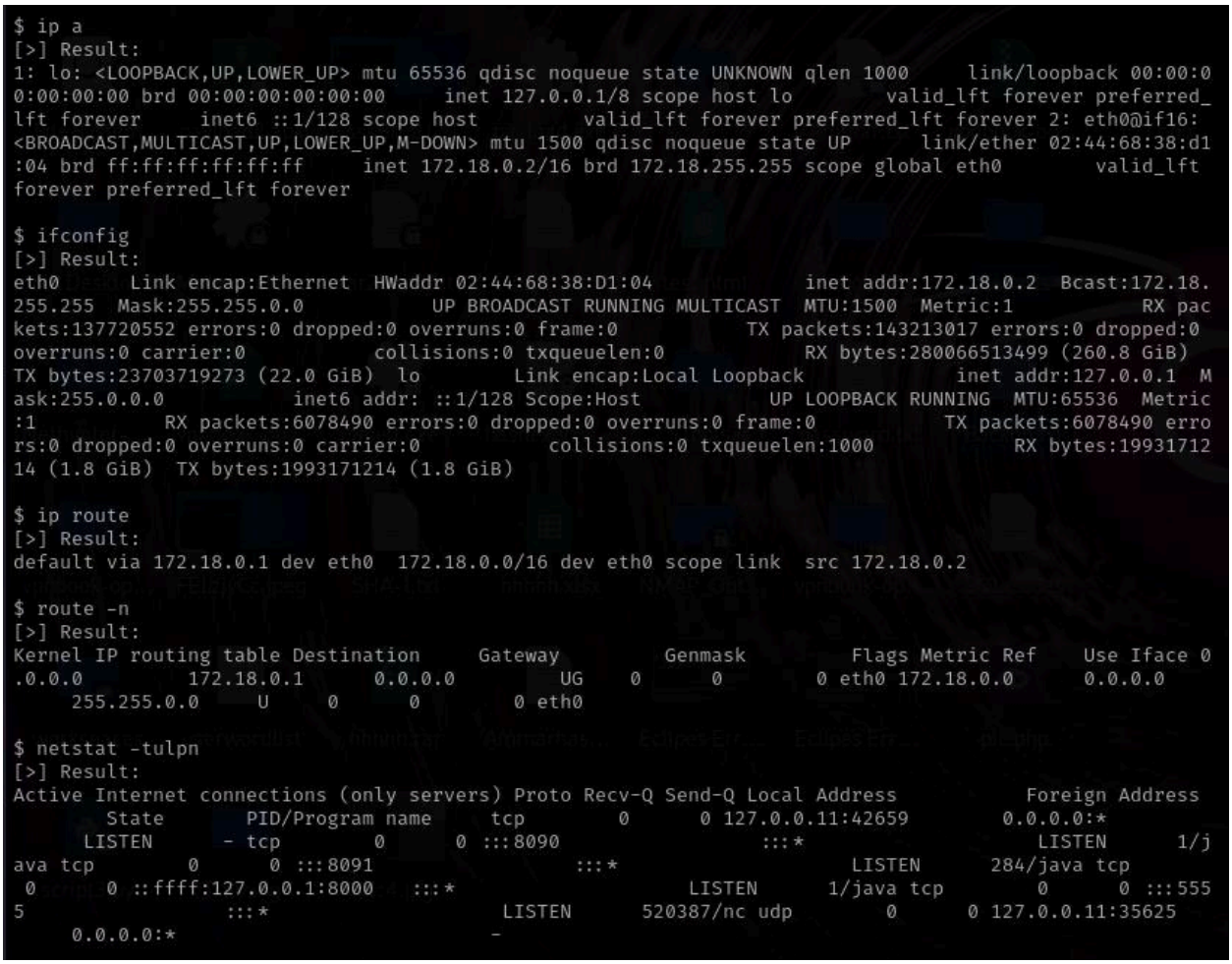



الشكل 2. مخرجات نظامية آمنة تظهر نظام التشغيل والنواة وبعض معلومات بيئة التنفيذ.

| الأمر الآمن | النتيجة المختصرة | الدلالة |
|---|---|---|
| whoami | root | تأكيد صلاحية التنفيذ داخل الحاوية |
| uname -a | Linux 6.8.0-106-generic x86_64 | تحديد النواة والمعمارية |
| cat /etc/os-release | Alpine Linux v3.9.4 | تحديد نظام التشغيل |
| hostname | d03b9e5e5d53 | اسم المضيف/الحاوية |
| env | CONF_VERSION=7.9.3 | تحديد إصدار Confluence المرصود |




الشكل ٣. مخرجات المستخدمين وصلاحيات الحسابات، وتأكيد وجود المستخدم root ضمن سياق التنفيذ.




الشكل ٤. مخرجات إعدادات الشبكة والخدمات المفتوحة، وتشمل عنوان الحاوية الداخلي والخدمات المستمعة.

```
$ [>] Result:
Filesystem                Size      Used Available Use% Mounted on overlay                  74.8G
3.6G     68.1G   5% / tmpfs                    64.0M         0     64.0M   0% /dev shm
      2.0G      5.7M      2.0G   0% /dev/shm /dev/sda1                74.8G      3.6G     68.1G   5% /e
tc/resolv.conf /dev/sda1                74.8G      3.6G     68.1G   5% /etc/hostname /dev/sda1
       74.8G      3.6G     68.1G   5% /etc/hosts /dev/sdb                 99.9G     71.4G     28.6G  71
% /var/atlassian/confluence /dev/sda1               74.8G      3.6G     68.1G   5% /opt/atlassian/conf
luence/logs tmpfs                     3.8G         0      3.8G   0% /proc/acpi tmpfs
 64.0M         0     64.0M   0% /proc/interrupts tmpfs                    64.0M         0     64.0M   0
% /proc/kcore tmpfs                   64.0M         0     64.0M   0% /proc/keys tmpfs
   64.0M         0     64.0M   0% /proc/latency_stats tmpfs                    3.8G         0      3.8
G   0% /proc/scsi tmpfs                   64.0M         0     64.0M   0% /proc/timer_list tmpfs
             3.8G         0      3.8G   0% /sys/firmware
```

الشكل ٥. مخرجات أنظمة الملفات ونقاط التركيب، وتوضح مساحة التخزين ومجلد بيانات Confluence.

```
$ [>] Result:
-rwxr-xr-x    1 root     root             0 Apr  3 14:38 /.dockerenv
```

الشكل ٦. مخرجات Docker.

```
 GNU nano 8.4                                    expliot2.py
#!/usr/bin/env python3
import re
import requests
import argparse
import urllib3

# pyright: reportOptionalMemberAccess=false
urllib3.disable_warnings(urllib3.exceptions.InsecureRequestWarning)

# Global variable for the args
args = None

def log_success(msg: str):
    """
    Logs a success message to stdout

    Arguments:
        msg(str): The message to log
    """
    print(f"[+] {msg}")

def log_failure(msg: str):
    """
    Logs a failure message to stdout

    Arguments:
        msg(str): The message to log
    """
    print(f"[-] {msg}")

def log_info(msg: str):
    """
    Logs a info message to stdout

    Arguments:
        msg(str): The message to log
    """
    print(f"[*] {msg}")

def log_result(msg: str):
    """
    Logs a result message to stdout

    Arguments:
        msg(str): The message to log
    """
    print(f"[>] {msg}")
```

الشكل ٧. PoC exploit2.py.




الشكل ٨. PoC exploit2.py.




الشكل ٩. PoC exploit2.py.

## 8. مؤشرات الاختراق والملاحظات التشغيلية

إضافة إلى الثغرة الأساسية، ظهرت عدة مؤشرات تستحق الفحص من فريق الاستجابة للحوادث. هذه المؤشرات لا تُستخدم كتعليمات تشغيلية، بل كعناصر تحقق واحتواء.

| المؤشر | القيمة المرصودة | التقييم |
|---|---|---|
| منفذ غير معتاد | TCP/5555 بواسطة nc | مرتفع: قد يشير إلى قناة وصول أو اختبار غير موثق |
| مهمة مجدولة خارجية | طلب دوري إلى [redacted] | مرتفع: يجب عزلها وفحصها قبل الحذف |
| اتصال/طلب خارجي ظاهر في العمليات | localto.net:8479/test | متوسط إلى مرتفع: يحتاج مراجعة سياق النشاط |
| تشغيل Java بصلاحية root | PID 1 وعمليات مرتبطة بالتطبيق | مرتفع: يوسع أثر أي استغلال للتطبيق |
| وجود حاوية Docker | dockerenv/. | معلومة سياقية: يتطلب فحص الحاوية والمضيف والشبكة الداخلية |
| سجلات shell فارغة | root/.bash_history فارغ | غير حاسم: قد يكون طبيعياً في الحاويات أو نتيجة تنظيف/عدم تسجيل |

### إجراءات احتواء مقترحة

- عزل الخادم أو تقييد الوصول الخارجي مؤقتاً حتى انتهاء الفحص.
- جمع نسخة من سجلات Confluence وTomcat وDocker والشبكة قبل إجراء تغييرات واسعة.
- إيقاف أي مهمة مجدولة أو عملية غير معروفة بعد توثيقها والتحقق من مالكها.
- تدوير الأسرار المحتملة: كلمات مرور، مفاتيح API، رموز جلسات، شهادات، وبيانات اتصال قاعدة البيانات.
- فحص المضيف الحاضن للحاوية للتأكد من عدم وجود تحرك جانبي أو وصول إلى volumes أخرى.

## 9. تحليل الأثر

يعرض هذا القسم أثر الثغرة على أبعاد السرية والسلامة والتوافر، مع ربط الأثر بالأدلة المرصودة في بيئة الهدف.

| البعد الأمني | الأثر المحتمل | مستوى الأثر |
|---|---|---|
| السرية | قراءة ملفات التطبيق، الإعدادات، السجلات، والبيانات المخزنة أو المجلدات المركبة. | عالٍ جداً |
| السلامة | تعديل ملفات التطبيق أو الإعدادات أو زرع مؤشرات استمرارية داخل الحاوية. | عالٍ جداً |
| التوافر | تعطيل خدمة Confluence أو استهلاك الموارد أو العبث بالعمليات. | عالٍ |
| التحرك الجانبي | استخدام الحاوية كنقطة انطلاق لفحص الشبكة الداخلية أو الوصول إلى البوابة. | متوسط إلى عالٍ |
| الامتثال والسمعة | احتمال تسرب وثائق داخلية أو بيانات مستخدمين وضرورة إشعار داخلي/خارجي حسب السياسة. | عالٍ |

### الأثر العملي على بيئة Confluence

- مجلد البيانات /var/atlassian/confluence يبدو مركباً على قرص مستقل، ما يعني أن الوصول بصلاحية عالية داخل الحاوية قد يطال بيانات التطبيق الفعلية.
- وجود Java/Tomcat وSynchrony ضمن العمليات يوضح أن المهاجم قد يؤثر في التطبيق الأساسي ومكونات التعاون اللحظي.
- المنفذ غير المعتاد والمهمة المجدولة الخارجية يرفعان احتمال أن الخادم تعرض لنشاط بعد الاستغلال، لذلك يجب التعامل مع الحالة كحادث أمني محتمل.

## 10. خطة المعالجة والتوصيات

| الأولوية | الإجراء | الهدف |
|---|---|---|
| فورية | عزل الخدمة أو تقييد الوصول إلى Confluence عبر VPN/WAF/قوائم سماح مؤقتة. | إيقاف قابلية الاستغلال من الإنترنت |
| فورية | أخذ نسخ من السجلات والملفات المشبوهة والعمليات قبل التغيير. | حفظ الأدلة ودعم التحقيق |
| فورية | ترقية Confluence إلى إصدار آمن ومدعوم وفق إرشادات Atlassian الرسمية. | إزالة سبب الثغرة |
| فورية | إزالة العمليات والمهمات المجدولة غير المعروفة بعد توثيقها وتحليلها. | إنهاء أي استمرارية محتملة |
| عالية | تدوير كلمات المرور والمفاتيح والرموز والشهادات ذات الصلة. | تقليل أثر التسرب المحتمل |
| عالية | تشغيل التطبيق بمستخدم غير root وتقييد صلاحيات الحاوية والـ volumes. | تقليل الأثر عند الاستغلال |
| عالية | تفعيل مراقبة السجلات والتنبيهات على أنماط استغلال Confluence وعمليات shell غير المعتادة. | الكشف المبكر عن إعادة الاستغلال |
| متوسطة | تحديث Java والمكونات القديمة وضبط TLS وفق سياسة أمنية حديثة. | تحسين الوضع الأمني العام |

بعد تنفيذ البنود العاجلة، يوصى بإضافة فحص دوري للإصدارات والثغرات وربطه بإدارة التغيير، مع الاحتفاظ بسجلات مركزية خارج الخادم.

## 11. قائمة إعادة الاختبار

بعد تطبيق المعالجة، يجب تنفيذ إعادة اختبار للتحقق من زوال الثغرة والمؤشرات المصاحبة. القائمة التالية تصلح كقائمة فحص للتسليم النهائي بعد الإصلاح.

| # | البند المطلوب التحقق منه | الحالة |
|---|---|---|
| 1 | التأكد من أن إصدار Confluence أصبح إصداراً آمناً ومدعوماً. | ☐ |
| 2 | التأكد من فشل أي محاولة تحقق من CVE-2022-26134 دون مصادقة. | ☐ |
| 3 | التأكد من عدم وجود تنفيذ أوامر غير مصرح به عبر واجهة Confluence. | ☐ |
| 4 | فحص العمليات والتأكد من غياب nc أو أي shell/listener غير موثق. | ☐ |
| 5 | مراجعة crontab والتأكد من عدم وجود طلبات خارجية غير معتمدة. | ☐ |
| 6 | فحص مجلدات Confluence بحثاً عن ملفات أو إضافات غير معروفة. | ☐ |
| 7 | تدوير الأسرار والتحقق من عدم تسرب بيانات الاعتماد في السجلات. | ☐ |
| 8 | مراجعة سجلات الوصول للتأكد من تاريخ بداية الاستغلال ونطاقه. | ☐ |
| 9 | التأكد من تشغيل التطبيق بمستخدم محدود الصلاحيات وليس root. | ☐ |
| 10 | تفعيل مراقبة وتنبيهات مستمرة للحوادث المشابهة. | ☐ |

## 12. الخاتمة والمراجع

أثبت الاختبار وجود ثغرة حرجة في بيئة Confluence تسمح بتنفيذ أوامر عن بعد دون مصادقة، وتم تأكيد أثرها من خلال تنفيذ أوامر نظامية آمنة أظهرت صلاحية root داخل الحاوية. وبالنظر إلى المؤشرات التشغيلية المصاحبة، يجب التعامل مع الحالة كحادث أمني محتمل يتطلب احتواءً سريعاً وتحقيقاً فنياً، وليس كتحديث عادي فقط.

### التوصية النهائية

- البدء الفوري بخطة احتواء وتحديث ثم إعادة اختبار.
- عدم إعادة الخدمة للإنترنت قبل التحقق من إزالة مؤشرات الاستمرارية وتدوير الأسرار الحساسة.
- اعتماد سياسة إدارة ثغرات دورية لتجنب بقاء مكونات حرجة بإصدارات قديمة.

### المراجع

| المرجع | الوصف |
|---|---|
| Atlassian Security Advisory | Confluence Server and Data Center - CVE-2022-26134 |
| NVD | CVE-2022-26134 Detail - CVSS v3.1 Critical 9.8 |
| الأدلة المقدمة من منفذ الاختبار | لقطات شاشة ومخرجات أوامر نظامية للهدف محل التقرير |

### ملحق مختصر: بيانات مهمة من الأدلة

| العنصر | القيمة |
|---|---|
| Target | [redacted]:443 |
| Protocol | HTTPS |
| Observed user | root |
| Hostname | d03b9e5e5d53 |
| OS | Alpine Linux 3.9.4 |
| Confluence version | 7.9.3 |
| Internal IP | 16/172.18.0.2 |